

PREFEITURA MUNICIPAL DE RIO DAS OSTRAS

Secretaria de Governança e Transformação Digital — GOVTIC

MINUTA DE DECRETO

Política Municipal de Desenvolvimento Descentralizado de Soluções Digitais e de Uso
Responsável de Inteligência Artificial

**VERSÃO CONSOLIDADA PARA ANÁLISE — DECRETO + QUATRO
ANEXOS**

Rio das Ostras — RJ
1º de setembro de 2026

Documento preliminar. A redação final deve ser submetida à Procuradoria-Geral do Município, ao Encarregado de Proteção de Dados, ao CGTI e às unidades administrativas competentes.

DECRETO Nº ____/2026**Institui a Política Municipal de Desenvolvimento Descentralizado de Soluções Digitais e de Uso Responsável de Inteligência Artificial no âmbito do Poder Executivo do Município de Rio das Ostras, estabelece regras para soluções digitais criadas por agentes públicos e dá outras providências.**

O PREFEITO DO MUNICÍPIO DE RIO DAS OSTRAS, Estado do Rio de Janeiro, no uso das atribuições que lhe são conferidas pelo inciso I, alínea “g”, do art. 100 da Lei Orgânica do Município de Rio das Ostras,

CONSIDERANDO os princípios da legalidade, impessoalidade, moralidade, publicidade, eficiência, segurança jurídica, prevenção, transparência, proteção de dados pessoais e continuidade do serviço público;

CONSIDERANDO a Lei Federal nº 13.709, de 14 de agosto de 2018 — Lei Geral de Proteção de Dados Pessoais — LGPD, a Lei Federal nº 12.527, de 18 de novembro de 2011 — Lei de Acesso à Informação, a Lei Federal nº 12.965, de 23 de abril de 2014 — Marco Civil da Internet, a Lei Federal nº 14.129, de 29 de março de 2021 — Lei de Governo Digital, e a Lei Federal nº 14.133, de 1º de abril de 2021;

CONSIDERANDO os Decretos Municipais nº 3.250/2022, nº 4.060/2024, nº 4.114/2024, nº 4.132/2024, nº 4.133/2024, nº 4.134/2024, nº 4.135/2024 e nº 4.422/2025, bem como as normas municipais que os complementem ou substituam;

CONSIDERANDO a necessidade de incentivar a inovação realizada pelas unidades administrativas, sem permitir a formação de sistemas paralelos sem responsável, sem documentação, sem controles mínimos de segurança ou incompatíveis com a arquitetura tecnológica municipal;

CONSIDERANDO que o uso de inteligência artificial generativa para produzir código-fonte não elimina os deveres de revisão humana, teste, segurança, proteção de dados, manutenção e prestação de contas;

DECRETA:**CAPÍTULO I — DAS DISPOSIÇÕES GERAIS**

Art. 1º Fica instituída a Política Municipal de Desenvolvimento Descentralizado de Soluções Digitais e de Uso Responsável de Inteligência Artificial, com a finalidade de permitir inovação segura, proporcional e rastreável no âmbito do Poder Executivo Municipal.

Art. 2º Este Decreto aplica-se aos órgãos e entidades da Administração Pública Municipal direta, autárquica e fundacional e às pessoas que, a qualquer título, desenvolvam, adquiram, configurem, mantenham, utilizem ou administrem soluções digitais relacionadas ao serviço público.

§ 1º As empresas públicas, sociedades de economia mista e demais entidades controladas pelo Município poderão adotar esta Política por ato próprio ou instrumento de adesão.

§ 2º Este Decreto alcança soluções produzidas com programação tradicional, inteligência artificial generativa, agentes de IA, plataformas low-code ou no-code, planilhas automatizadas, macros, scripts, robôs, formulários, bancos de dados locais e ferramentas equivalentes.

§ 3º A Política aplica-se à solução cujo código tenha sido criado com auxílio de IA ainda que a solução final não contenha componente de inteligência artificial em execução.

Art. 3º Para os fins deste Decreto, considera-se:

I — solução digital: aplicação, script, automação, banco de dados, planilha programada, painel, robô, formulário, fluxo, integração ou artefato computacional utilizado para apoiar, registrar ou executar atividade pública;

- II — desenvolvimento descentralizado: criação ou manutenção de solução digital por unidade de negócio ou por agente que não integra a equipe central de desenvolvimento de sistemas da GOVTIC;
- III — desenvolvedor setorial: agente público, estagiário, empregado, contratado ou colaborador que cria ou mantém solução digital fora da equipe central de desenvolvimento;
- IV — proprietário do processo de negócio: autoridade ou gestor da unidade responsável pela finalidade pública, pelos dados, pelas regras de negócio e pela continuidade da atividade apoiada pela solução;
- V — mantenedor: pessoa formalmente indicada para corrigir, atualizar, documentar e prestar o suporte operacional da solução;
- VI — inteligência artificial — IA: sistema computacional capaz de produzir previsões, recomendações, classificações, decisões ou conteúdos a partir de dados ou instruções;
- VII — IA generativa: sistema capaz de gerar ou modificar texto, imagem, áudio, vídeo, código-fonte ou outros conteúdos;
- VIII — desenvolvimento assistido por IA: uso de IA generativa para conceber, escrever, explicar, revisar, testar, alterar ou implantar software;
- IX — “vibe coding”: expressão coloquial que designa a criação acelerada de software por instruções em linguagem natural e geração automatizada de código, especialmente quando realizada sem domínio técnico suficiente para avaliar integralmente o resultado;
- X — ferramenta pública externa de IA: serviço de IA disponível ao público, gratuito ou pago, que não tenha sido contratado, homologado ou disponibilizado institucionalmente pelo Município;
- XI — homologação: decisão formal de aceitação técnica e operacional pela GOVTIC, que não se confunde com simples registro, orientação, conectividade ou ciência;
- XII — registro autoritativo: dado ou documento considerado fonte oficial para comprovação de ato, direito, obrigação, pagamento, atendimento, decisão ou situação administrativa;
- XIII — dado não público: informação interna, restrita, sigilosa, pessoal ou pessoal sensível que não esteja legitimamente disponibilizada ao público;
- XIV — solução institucional: solução destinada a mais de uma unidade administrativa, integrada a sistemas oficiais, utilizada como registro autoritativo ou incluída no catálogo oficial de serviços de TIC;
- XV — solução de alto impacto: solução que possa afetar direitos, benefícios, obrigações, liberdade, integridade física, acesso a serviço público essencial ou decisão administrativa relevante;
- XVI — Catálogo Municipal de Tecnologias Recomendadas e Suportadas: ato técnico que relaciona linguagens, bancos de dados, componentes, versões, padrões, ferramentas e ambientes aceitos, recomendados ou suportados pelo Município.

Art. 4º A Política observará os seguintes princípios:

- I — inovação responsável e simplificação administrativa;
- II — proporcionalidade entre controles e risco;
- III — responsabilidade e supervisão humana;
- IV — segurança e privacidade desde a concepção;
- V — minimização de dados e limitação de finalidade;
- VI — documentação, rastreabilidade e auditabilidade;
- VII — interoperabilidade, portabilidade e prevenção de dependência tecnológica injustificada;
- VIII — uso de padrões abertos e tecnologias sustentáveis;
- IX — acessibilidade, inclusão e foco no usuário;
- X — continuidade do serviço público e preservação do conhecimento institucional;
- XI — separação entre ambiente de experimentação e ambiente de produção; e
- XII — presunção de boa-fé, sem prejuízo do dever de diligência e da responsabilização por conduta dolosa ou culposa.

Art. 5º São objetivos da Política:

- I — permitir que agentes públicos automatizem tarefas de baixo risco sem procedimento desnecessariamente complexo;
- II — identificar e regularizar soluções digitais paralelas ou desconhecidas;
- III — impedir que protótipos se convertam em sistemas críticos sem governança;
- IV — proteger dados pessoais, informações sigilosas, credenciais, código-fonte e infraestrutura municipal;
- V — estabelecer responsáveis por negócio, manutenção, suporte, segurança e continuidade;
- VI — padronizar tecnologias e reduzir custos de operação e manutenção;
- VII — assegurar revisão humana e qualidade do código gerado por IA; e
- VIII — criar caminho de incorporação das soluções setoriais de comprovado valor ao portfólio oficial.

Art. 6º A aplicação deste Decreto deverá evitar controles superiores ao risco efetivo da solução, priorizando formulários simplificados, orientações automáticas, modelos reutilizáveis e análise técnica apenas nos casos de maior alcance, criticidade ou exposição.

CAPÍTULO II — DA GOVERNANÇA E DAS RESPONSABILIDADES INSTITUCIONAIS

Art. 7º Compete ao Comitê Gestor de Tecnologia da Informação — CGTI, sem prejuízo das competências previstas no Decreto Municipal nº 4.422/2025:

- I — aprovar diretrizes, padrões e critérios complementares desta Política;
- II — deliberar sobre exceções tecnológicas de impacto institucional;
- III — deliberar sobre soluções classificadas no Nível 4, observado o apoio técnico, jurídico e de proteção de dados;
- IV — aprovar o Catálogo Municipal de Tecnologias Recomendadas e Suportadas;
- V — instituir grupo de trabalho ou comissão técnica para inteligência artificial e desenvolvimento descentralizado; e
- VI — acompanhar relatório anual de inventário, riscos, incidentes e resultados da Política.

Art. 8º Compete à Secretaria de Governança e Transformação Digital — GOVTIC, como unidade central de governança técnica:

- I — manter o inventário municipal de soluções descentralizadas e de sistemas de IA;
- II — disponibilizar formulários, modelos, guias, componentes reutilizáveis, trilhas de capacitação e listas de verificação;
- III — classificar ou reclassificar soluções quando necessário;
- IV — emitir parecer técnico para os Níveis 3 e 4;
- V — manter catálogo de ferramentas de IA homologadas e indicar quais categorias de informação podem ser tratadas em cada uma;
- VI — definir padrões mínimos de arquitetura, segurança, interoperabilidade, banco de dados, hospedagem, desenvolvimento e ciclo de vida;
- VII — realizar auditorias, análise de código, testes de segurança e diligências proporcionais ao risco;
- VIII — coordenar, no âmbito técnico, a contenção de incidentes e a proteção da infraestrutura municipal;
- IX — recomendar suspensão, bloqueio, isolamento, correção ou descontinuação de solução que represente risco relevante; e
- X — publicar relatório anual consolidado, resguardadas informações que possam comprometer a segurança, o sigilo ou a proteção de dados.

Art. 9º O Encarregado pelo Tratamento de Dados Pessoais e as unidades municipais responsáveis por privacidade e controle interno atuarão conforme suas competências, especialmente na orientação, no mapeamento de dados, na análise de riscos, no Relatório de Impacto à Proteção de Dados Pessoais — RIPD e no tratamento de incidentes.

Art. 10. Compete ao proprietário do processo de negócio e à autoridade máxima da pasta ou entidade:

- I — autorizar a criação ou o uso continuado da solução;
- II — assegurar finalidade pública, competência legal, base legal de tratamento e adequação às normas da unidade;
- III — designar o responsável principal e, para os Níveis 2 a 4, ao menos um substituto;
- IV — garantir recursos, tempo e condições para manutenção, suporte e continuidade;
- V — manter atualizado o mapeamento dos dados e fluxos de tratamento;
- VI — decidir, com apoio das áreas competentes, sobre correção, substituição ou descontinuação; e
- VII — responder pela qualidade das regras de negócio e pelo uso administrativo dos resultados.

Art. 11. O desenvolvedor setorial e o mantenedor respondem, no âmbito de suas atribuições, pela veracidade das informações prestadas no registro, pela diligência técnica, pela revisão dos resultados gerados por IA, pela documentação, pelos testes, pela comunicação de incidentes e pela entrega do conhecimento institucional.

Art. 12. O registro de uma solução, a prestação de orientação, a disponibilização de conectividade, a análise pontual, a resposta a incidente ou a permissão de acesso à rede não constituem homologação, incorporação ao catálogo oficial, assunção de manutenção ou garantia de nível de serviço pela GOVTIC.

CAPÍTULO III — DA CLASSIFICAÇÃO DAS SOLUÇÕES

Art. 13. As soluções abrangidas por este Decreto serão classificadas segundo seu alcance e risco:

- I — Nível 0 — Experimento ou protótipo isolado;
- II — Nível 1 — Solução de uso individual;
- III — Nível 2 — Solução setorial;
- IV — Nível 3 — Solução institucional; e
- V — Nível 4 — Solução crítica ou de alto impacto.

Art. 14. Classifica-se no Nível 0 a prova de conceito temporária, não compartilhada e não conectada a ambiente de produção.

§ 1º O Nível 0 somente poderá utilizar dados sintéticos, fictícios, legitimamente públicos ou adequadamente anonimizados, sendo vedado o uso de credenciais institucionais, dados reais não públicos e integração com sistemas oficiais.

§ 2º A experimentação poderá ocorrer por até 60 (sessenta) dias sem autorização prévia ou registro, desde que permaneça estritamente nas condições deste artigo.

§ 3º Antes de ser compartilhado, usado de forma recorrente ou conectado a qualquer dado ou serviço real, o experimento deverá ser registrado e reclassificado.

Art. 15. Classifica-se no Nível 1 a solução utilizada exclusivamente pelo próprio agente para produtividade pessoal, sem criar registro autoritativo, atender público externo, integrar sistema oficial ou tratar dado pessoal sensível, sigiloso ou restrito.

§ 1º A solução de Nível 1 que armazene dados de trabalho ou seja utilizada de forma recorrente deverá ser objeto de registro simplificado e ciência da chefia imediata.

§ 2º A expressão “uso individual” define apenas o alcance da solução e não atribui propriedade privada sobre código, dados ou documentos produzidos no exercício funcional.

Art. 16. Classifica-se no Nível 2 a solução de uso interno limitada a uma única unidade administrativa ou setor, destinada a grupo restrito de usuários e sem enquadramento nos Níveis 3 ou 4.

§ 1º O Nível 2 exige autorização do proprietário do processo de negócio, registro prévio, indicação de mantenedor e substituto, repositório de código ou versão controlada, documentação mínima, controle de acesso, cópia de segurança e plano de descontinuação.

§ 2º O tratamento de dados pessoais não sensíveis no Nível 2 dependerá de finalidade pública, base legal, minimização, controle de acesso e registro do fluxo de tratamento.

§ 3º A presença de dado pessoal sensível, sigilo legal, decisão sobre direito ou risco relevante poderá determinar classificação superior.

Art. 17. Classifica-se no Nível 3 a solução que atenda a mais de uma unidade, integre sistema oficial, utilize domínio público municipal, constitua registro autoritativo, suporte processo administrativo relevante ou se destine a continuidade institucional.

Parágrafo único. O Nível 3 exige análise e homologação prévias da GOVTIC, hospedagem ou ambiente aprovado, observância integral dos padrões corporativos, gestão formal de mudanças, monitoramento, documentação técnica e funcional, testes, cópias de segurança e definição de nível de serviço.

Art. 18. Classifica-se no Nível 4 a solução que:

- I — seja destinada diretamente a cidadãos, empresas ou público externo e realize coleta de dados ou transação;
- II — apoie ou produza decisão que possa conceder, negar, suspender ou modificar direito, benefício, obrigação, sanção, licença, autorização ou acesso a serviço público essencial;
- III — trate em escala relevante dados pessoais sensíveis, biométricos, de crianças e adolescentes, saúde, assistência social, educação, segurança pública, recursos humanos, folha de pagamento, tributos, finanças, licitações ou contratos;
- IV — opere infraestrutura crítica, segurança física ou cibernética;
- V — realize perfilamento, pontuação, ranqueamento, predição comportamental ou detecção de fraude com consequências relevantes;
- VI — utilize agente autônomo com capacidade de executar ações em sistemas de produção; ou
- VII — apresente risco elevado segundo avaliação da GOVTIC, do Encarregado ou do CGTI.

§ 1º A solução de Nível 4 não poderá ser implantada de forma independente por desenvolvedor setorial.

§ 2º A implantação dependerá de avaliação técnica, jurídica, de proteção de dados e de impacto, bem como de deliberação favorável do CGTI, quando aplicável.

Art. 19. A classificação observará o critério de maior risco, independentemente do nome, do tamanho, do número de linhas de código, da gratuidade da ferramenta ou da alegação de uso experimental.

Parágrafo único. A ampliação de usuários, dados, integrações, finalidade, publicidade ou criticidade exige atualização do registro e nova classificação antes da mudança.

Art. 20. Ficam vedadas, em qualquer nível:

- I — criação de solução destinada a prática ilícita, discriminação, vigilância abusiva, manipulação indevida ou violação de direitos fundamentais;
- II — uso de credenciais compartilhadas, senhas inseridas no código-fonte ou chaves publicadas em repositório;
- III — implantação deliberada de código malicioso, componente sem licença compatível ou dependência sabidamente comprometida;
- IV — ocultação de solução, banco de dados, incidente, vulnerabilidade grave ou tratamento de dados pessoais da unidade competente;
- V — apresentação de protótipo como sistema oficial ou uso de identidade visual, domínio ou marca institucional capaz de induzir o público em erro;
- VI — decisão administrativa exclusivamente automatizada com efeito relevante, sem previsão legal, supervisão humana e possibilidade de revisão; e
- VII — utilização de IA para gerar, alterar ou excluir dados em produção sem mecanismos de autorização, validação, registro e reversão.

CAPÍTULO IV — DO REGISTRO, DA AUTORIZAÇÃO E DO CICLO DE VIDA

Art. 21. Fica instituído o Inventário Municipal de Soluções Digitais Descentralizadas e de Sistemas de Inteligência Artificial, mantido pela GOVTIC.

§ 1º O inventário deverá conter, no mínimo, finalidade, unidade proprietária, responsáveis, usuários, classificação, tecnologias, ferramentas de IA utilizadas, dados tratados, integrações, hospedagem, cópias de segurança, situação de homologação e data de revisão.

§ 2º Informações de segurança, arquitetura interna, vulnerabilidades, credenciais e dados protegidos não serão objeto de divulgação pública.

§ 3º O registro poderá ser integrado ao inventário de ativos de TIC existente.

Art. 22. Os Níveis 1 e 2 seguirão procedimento simplificado, preferencialmente eletrônico e autodeclaratório, com orientação automática sobre risco e controles mínimos.

§ 1º O silêncio da GOVTIC no procedimento simplificado não constitui homologação.

§ 2º A GOVTIC poderá solicitar complementação, correção ou reclassificação a qualquer tempo.

Art. 23. Os Níveis 3 e 4 dependerão de demanda formal e avaliação prévia, com documentação proporcional ao risco e vedação de entrada em produção antes da aprovação aplicável.

Art. 24. A solução de Nível 4 deverá apresentar, conforme o caso:

I — análise de viabilidade e necessidade;

II — avaliação de impacto algorítmico — AIA;

III — Relatório de Impacto à Proteção de Dados Pessoais — RIPD;

IV — análise de segurança e arquitetura;

V — plano de testes, validação, monitoramento e resposta a incidentes;

VI — plano de reversibilidade e descontinuação;

VII — parecer jurídico quando houver efeito relevante sobre direitos, contratação, propriedade intelectual ou transferência de dados; e

VIII — definição expressa de supervisão humana, explicabilidade e canal de contestação.

Art. 25. A GOVTIC poderá disponibilizar ambiente municipal de experimentação ou sandbox para soluções de Níveis 0 a 2, com dados sintéticos ou anonimizados, prazo definido, segregação, logs, limites de acesso e eliminação ao término.

Art. 26. A incorporação de solução setorial ao portfólio oficial dependerá de aceite formal da GOVTIC, análise de código, documentação, arquitetura, segurança, licenças, dados, capacidade operacional, custos de manutenção e disponibilidade de equipe.

Parágrafo único. A simples utilidade ou ampla adoção de solução não obriga a GOVTIC a incorporá-la sem recursos, adequação e priorização pelo CGTI.

Art. 27. As soluções de Níveis 2 a 4 serão reavaliadas pelo menos anualmente e sempre que ocorrer alteração relevante, incidente, mudança de responsável, descontinuação de tecnologia ou expansão de escopo.

Parágrafo único. A descontinuação deverá prever exportação dos dados, preservação documental, revogação de acessos, eliminação segura, comunicação aos usuários e guarda conforme a tabela de temporalidade.

CAPÍTULO V — DO USO DE INTELIGÊNCIA ARTIFICIAL E DO CÓDIGO GERADO

Art. 28. Ferramentas públicas externas de IA poderão ser utilizadas para aprendizagem, ideação, exemplos genéricos e produção de conteúdo a partir de informação legitimamente pública, desde que não haja restrição específica e que o resultado seja revisto pelo agente competente.

Art. 29. É vedado inserir em ferramenta pública externa de IA não homologada:

I — dado pessoal, dado pessoal sensível ou informação que permita identificar pessoa natural;

II — informação interna, restrita, sigilosa ou protegida por segredo fiscal, funcional, profissional, comercial ou judicial;

III — credencial, senha, chave de API, token, certificado, segredo criptográfico ou configuração de acesso;

- IV — código-fonte não público, esquema de banco de dados, dump, log, mensagem de erro, topologia, endereço interno ou detalhe de arquitetura que possa aumentar risco de ataque;
- V — documento de contratação, parecer, processo, minuta decisória, investigação ou política ainda não publicada, quando não autorizado; e
- VI — conjunto de informações aparentemente isoladas cuja agregação revele conteúdo protegido.

Parágrafo único. Exemplos necessários à consulta deverão utilizar dados fictícios, sintéticos ou adequadamente anonimizados.

Art. 30. Código, consulta, configuração ou instrução gerada por IA será considerado conteúdo não confiável até que seja:

- I — compreendido por pessoa tecnicamente capaz de mantê-lo;
- II — revisado quanto a lógica, segurança, privacidade, desempenho, acessibilidade e licença;
- III — testado em ambiente segregado com casos normais, limites e falhas;
- IV — submetido a análise de dependências, vulnerabilidades e segredos;
- V — documentado em grau compatível com o risco; e
- VI — aprovado segundo a classificação da solução.

Parágrafo único. É vedada a justificativa de que o funcionamento do código não é compreendido porque foi produzido por inteligência artificial.

Art. 31. Agentes autônomos, assistentes de codificação e ferramentas de IA não poderão receber acesso irrestrito a ambiente de produção, banco de dados oficial, console administrativo, repositório principal ou infraestrutura crítica.

§ 1º A execução de comandos, migrações, exclusões ou alterações em produção exigirá autorização humana específica, registro, cópia de segurança ou mecanismo de reversão e segregação de privilégios.

§ 2º O uso de agente autônomo em Nível 4 dependerá de autorização expressa e controles adicionais definidos pela GOVTIC.

Art. 32. Para os Níveis 2 a 4, a documentação deverá registrar as ferramentas e modelos de IA relevantes utilizados no desenvolvimento, a data ou versão quando disponível, as partes substanciais geradas, o responsável pela revisão e os testes executados, sem necessidade de conservar conversas irrelevantes ou dados proibidos.

Art. 33. Conteúdo destinado ao público e significativamente gerado ou alterado por IA deverá passar por revisão humana e ser identificado quando a ausência de identificação puder induzir o destinatário em erro.

§ 1º O cidadão deverá ser informado quando interagir diretamente com agente automatizado.

§ 2º Decisão administrativa relevante permanecerá sob responsabilidade da autoridade competente e deverá admitir revisão humana e contestação nos termos da legislação.

CAPÍTULO VI — DOS PADRÕES TECNOLÓGICOS E DE SEGURANÇA

Art. 34. O PostgreSQL é definido como banco de dados relacional padrão e suportado para novas soluções institucionais desenvolvidas internamente pelo Município.

§ 1º O uso do PostgreSQL é obrigatório nos Níveis 3 e 4 quando a solução necessitar de banco de dados relacional, salvo exceção técnica aprovada nos termos do art. 35.

§ 2º Nos Níveis 0 a 2 poderão ser utilizados bancos locais, embarcados ou alternativos, desde que a solução permaneça dentro do alcance autorizado, não constitua registro autoritativo, possua exportação documentada e cumpra os controles de segurança e cópia de segurança aplicáveis.

§ 3º A ampliação de solução que utilize banco alternativo poderá exigir migração para PostgreSQL antes de sua homologação institucional.

Art. 35. A utilização de outro mecanismo de banco de dados nos Níveis 3 e 4 poderá ser autorizada pela GOVTIC ou pelo CGTI, conforme o impacto, mediante nota técnica que demonstre necessidade

especializada, benefícios, riscos, custos, suporte, interoperabilidade, portabilidade, cópia de segurança, recuperação e plano de saída.

Parágrafo único. Poderão justificar exceção, entre outros, requisitos de análise massiva, séries temporais, busca, grafos, documentos, cache, processamento analítico, funcionamento embarcado ou tecnologia legada indispensável.

Art. 36. A exigência de PostgreSQL para desenvolvimento interno não se aplica automaticamente à aquisição de software pronto, serviço em nuvem ou solução comercial, cuja especificação deverá preservar competição, adequação ao objeto, interoperabilidade, portabilidade, exportação integral dos dados, integração por padrões abertos e prevenção de dependência indevida de fornecedor.

Art. 37. A linguagem Dart é a linguagem preferencial e recomendada para novas aplicações desenvolvidas internamente, especialmente para soluções web, serviços de backend e aplicações multiplataforma alinhadas à arquitetura municipal.

§ 1º A recomendação não constitui exclusividade e não impede o uso de Python, JavaScript, TypeScript, PHP ou outra linguagem quando houver adequação técnica, disponibilidade de competências, integração, desempenho, ciência de dados, inteligência artificial, automação, legado ou vantagem comprovada.

§ 2º Soluções institucionais em linguagem diversa da arquitetura predominante deverão apresentar justificativa de manutenção, suporte, segurança e continuidade.

§ 3º O PHP poderá ser mantido em soluções legadas, devendo novas expansões relevantes considerar modernização, isolamento de riscos e plano de atualização.

Art. 38. O Catálogo Municipal de Tecnologias Recomendadas e Suportadas será aprovado pelo CGTI e atualizado por resolução ou norma técnica, de modo a permitir evolução tecnológica sem alteração deste Decreto.

Parágrafo único. O catálogo distinguirá, no mínimo, tecnologias preferenciais, permitidas, toleradas para legado, experimentais, não suportadas e vedadas.

Art. 39. Toda solução deverá observar controles proporcionais ao risco, incluindo, quando aplicáveis:

- I — controle de versão e repositório institucional;
- II — autenticação individual, menor privilégio e revogação de acesso;
- III — proteção de segredos fora do código-fonte;
- IV — criptografia em trânsito e proteção adequada em repouso;
- V — validação de entrada, consultas parametrizadas e tratamento seguro de arquivos;
- VI — inventário, atualização e verificação de dependências e licenças;
- VII — separação entre desenvolvimento, teste e produção;
- VIII — dados fictícios, mascarados ou anonimizados em testes;
- IX — logs e trilhas de auditoria sem exposição indevida de dados;
- X — cópia de segurança, teste de restauração e plano de continuidade;
- XI — testes funcionais, de segurança, desempenho e acessibilidade;
- XII — monitoramento e correção de vulnerabilidades;
- XIII — documentação de instalação, operação, modelo de dados, integrações e recuperação; e
- XIV — plano de manutenção, substituição e descontinuação.

Art. 40. É vedada a integração direta de solução descentralizada com banco de dados oficial sem autorização e credencial específica.

§ 1º As integrações deverão utilizar, preferencialmente, APIs, serviços, visões de leitura ou mecanismos intermediários aprovados, com escopo mínimo, logs e limitação de taxa.

§ 2º Não serão fornecidas credenciais administrativas ou compartilhadas para atender solução setorial.

Art. 41. Soluções de Níveis 1 e 2 não poderão ser publicadas em internet aberta, utilizar domínio oficial, hospedar dados municipais em conta pessoal ou serviço gratuito não autorizado, nem depender de conta cujo titular exclusivo seja pessoa física.

§ 1º A hospedagem de Nível 2 em rede interna ou serviço aprovado não implica suporte, monitoramento ou garantia de disponibilidade pela GOVTIC.

§ 2º A publicação externa e o uso de domínio municipal exigem classificação mínima no Nível 3 e homologação.

CAPÍTULO VII — DA MANUTENÇÃO, DO SUPORTE, DOS INCIDENTES E DA RESPONSABILIDADE

Art. 42. Nas soluções dos Níveis 1 e 2, caberá ao desenvolvedor setorial, ao mantenedor e à unidade proprietária, conforme atribuições formalizadas:

I — realizar manutenção corretiva, evolutiva e de segurança;

II — atender os usuários autorizados;

III — manter documentação, versões, dependências e cópias de segurança;

IV — acompanhar falhas, vulnerabilidades e mudanças de serviço de terceiros;

V — validar resultados e corrigir dados inconsistentes;

VI — comunicar incidentes e cooperar com a contenção; e

VII — assegurar a transferência de conhecimento e a descontinuação ordenada.

Art. 43. A unidade proprietária assumirá a responsabilidade administrativa e operacional primária pelas soluções de Níveis 1 e 2, inclusive quanto à finalidade, usuários, dados, manutenção, suporte e continuidade, sem prejuízo das competências institucionais previstas em lei ou regulamento.

Art. 44. A GOVTIC não será considerada responsável pela autoria, manutenção, correção, disponibilidade, recuperação, suporte aos usuários, nível de serviço, cópia de segurança ou evolução de solução de Níveis 1 e 2 que não tenha sido formalmente homologada e incorporada ao catálogo oficial.

§ 1º O disposto no caput não afasta o dever da GOVTIC de proteger a infraestrutura municipal, receber comunicações de incidentes, orientar segundo sua capacidade e adotar medidas de contenção.

§ 2º A atuação emergencial da GOVTIC não transfere para ela a titularidade técnica ou operacional da solução.

§ 3º A GOVTIC poderá recusar atendimento funcional ou manutenção de solução não homologada e orientar sua correção, suspensão, migração ou descontinuação.

Art. 45. A distribuição interna de atribuições prevista neste Decreto não altera a responsabilidade jurídica do Município, dos controladores, operadores, agentes de tratamento, autoridades e unidades prevista na LGPD e nas demais normas aplicáveis.

§ 1º A apuração de responsabilidade funcional, disciplinar, civil ou regressiva do agente observará sua participação, deveres, dolo ou culpa, nexos causal, orientações recebidas, capacidade técnica e o devido processo legal.

§ 2º É vedada cláusula ou termo que pretenda transferir integralmente ao agente público, perante titulares, terceiros ou órgãos de controle, obrigação legal que pertença ao Município ou ao controlador institucional.

Art. 46. Qualquer suspeita de vazamento, acesso indevido, perda, alteração, indisponibilidade relevante, uso indevido de IA, exposição de credenciais ou vulnerabilidade grave deverá ser comunicada imediatamente pelos canais oficiais de gestão de incidentes e à chefia responsável.

§ 1º Quando houver dados pessoais, o Encarregado e as unidades competentes deverão ser acionados sem demora.

§ 2º O agente deverá preservar evidências, interromper ações que ampliem o dano e seguir as orientações de contenção, sendo vedada a ocultação ou a tentativa de correção que destrua registros relevantes.

§ 3º A comunicação de boa-fé será considerada elemento favorável na avaliação da conduta.

Art. 47. A transferência, afastamento, férias prolongadas, desligamento ou impedimento do responsável exigirá entrega à chefia, em prazo definido pela unidade, de código-fonte, documentação, dados, chaves institucionais, instruções de operação, pendências e acesso ao repositório.

§ 1º Soluções de Nível 2 ou superior não poderão depender exclusivamente de uma única pessoa.

§ 2º Na ausência de mantenedor apto, a autoridade deverá suspender o uso, contratar suporte, promover migração ou descontinuar a solução, conforme o risco.

Art. 48. Código, documentação, modelos, bancos de dados, configurações e artefatos produzidos no exercício funcional ou com recursos municipais constituem ativos de informação do Município, observadas as licenças de terceiros e a legislação de propriedade intelectual.

Parágrafo único. É vedada a retenção exclusiva em dispositivo, e-mail, repositório ou conta pessoal.

CAPÍTULO VIII — DAS CONTRATAÇÕES E DOS SERVIÇOS DE TERCEIROS

Art. 49. A contratação, assinatura, aquisição ou renovação de ferramenta de IA, plataforma de desenvolvimento, hospedagem, banco de dados ou serviço relacionado observará a centralização e a análise técnica previstas na regulamentação municipal de TIC.

Art. 50. Os instrumentos de contratação de IA ou serviço em nuvem deverão prever, conforme o risco:

- I — finalidade, categorias de dados e locais de processamento;
- II — proibição de usar dados, prompts, respostas ou código municipal para treinamento ou finalidade própria sem autorização expressa e base jurídica;
- III — confidencialidade, controles de acesso, criptografia e gestão de suboperadores;
- IV — registro, auditoria e comunicação de incidentes em prazo compatível com as obrigações do Município;
- V — exclusão e devolução dos dados ao término;
- VI — portabilidade, exportação em formato aberto e assistência de transição;
- VII — níveis de serviço, continuidade, recuperação e suporte;
- VIII — propriedade intelectual, licenças de componentes e responsabilidade por violação;
- IX — possibilidade de verificação de controles, evidências e relatórios de segurança; e
- X — jurisdição, transferência internacional e atendimento à LGPD.

CAPÍTULO IX — DA CAPACITAÇÃO, DA AUDITORIA E DAS MEDIDAS DE PROTEÇÃO

Art. 51. A GOVTIC, em articulação com o CGTI, o Encarregado, o controle interno e a área de gestão de pessoas, promoverá capacitação proporcional ao papel do agente.

§ 1º O registro de solução de Nível 2 ou superior dependerá da conclusão de trilha básica ou da declaração de compromisso de conclusão no prazo definido.

§ 2º A capacitação abrangerá, no mínimo, LGPD, segurança, uso seguro de IA, revisão de código, gestão de credenciais, dependências, testes, cópia de segurança, incidentes e responsabilidade administrativa.

Art. 52. A GOVTIC e as unidades de controle poderão auditar soluções abrangidas por este Decreto e determinar, de forma motivada e proporcional:

- I — correção de vulnerabilidade ou documentação;
- II — limitação de usuários, dados, integração ou funcionalidade;
- III — redefinição de classificação;
- IV — rotação de credenciais, isolamento de rede ou bloqueio de acesso;
- V — suspensão cautelar quando houver risco relevante e imediato;
- VI — migração para ambiente institucional; ou
- VII — descontinuação e preservação dos dados necessários.

Parágrafo único. Sempre que o risco permitir, será concedido prazo razoável para adequação e apoio por meio de modelos ou orientação.

Art. 53. A regularização espontânea e de boa-fé de solução preexistente não acarretará sanção automática pelo simples fato de sua existência não registrada, sem prejuízo da correção imediata de risco grave e da apuração de conduta diversa, especialmente ocultação, uso indevido de dados ou descumprimento deliberado de determinação.

CAPÍTULO X — DAS DISPOSIÇÕES TRANSITÓRIAS E FINAIS

Art. 54. As soluções em uso na data de publicação deste Decreto deverão:

- I — ser comunicadas pela unidade proprietária em até 90 (noventa) dias;
- II — ter as soluções possivelmente enquadradas no Nível 4 identificadas e comunicadas em até 30 (trinta) dias;
- III — concluir classificação e plano de adequação em até 180 (cento e oitenta) dias; e
- IV — ser suspensas de imediato quando apresentarem risco grave e atual que não possa ser mitigado provisoriamente.

Art. 55. O CGTI e a GOVTIC editarão, no prazo de até 90 (noventa) dias, os atos complementares necessários, incluindo:

- I — formulário de registro e termo de ciência;
- II — matriz de classificação;
- III — controles mínimos por nível;
- IV — Catálogo Municipal de Tecnologias Recomendadas e Suportadas;
- V — catálogo de ferramentas de IA homologadas;
- VI — modelo simplificado de documentação e plano de continuidade;
- VII — procedimento de exceção tecnológica; e
- VIII — trilha de capacitação.

Art. 56. As referências, em normas municipais anteriores, a estruturas de tecnologia da informação sucedidas ou reorganizadas serão compreendidas como dirigidas à unidade que detenha a competência correspondente na estrutura vigente, sem prejuízo de ajuste formal das normas.

Art. 57. Este Decreto complementa as políticas municipais de segurança da informação, proteção de dados, gestão de ativos, controle de acesso, cópia de segurança, incidentes e centralização de TIC, prevalecendo a regra mais protetiva quando houver compatibilidade e cabendo ao CGTI dirimir dúvida técnica.

Art. 58. Este Decreto entra em vigor na data de sua publicação.

Rio das Ostras, ____ de _____ de 2026.

PREFEITO DO MUNICÍPIO DE RIO DAS OSTRAS

ANEXO I

MATRIZ DE CLASSIFICAÇÃO E RITO PROPORCIONAL

Nível	Exemplo e alcance	Dados e exposição	Rito mínimo	Responsabilidade de suporte
0 — Experimento	Protótipo isolado, temporário, não compartilhado e sem produção.	Somente dados sintéticos, fictícios, públicos ou anonimizados; sem credenciais e integrações.	Sem registro por até 60 dias; registrar antes de compartilhar ou usar dados reais.	Do autor; nenhuma garantia da GOVTIC.
1 — Individual	Script, planilha ou aplicação usada por um único agente.	Sem dado sensível, sigiloso, registro autoritativo, integração ou público externo.	Registro simplificado quando recorrente ou com dados de trabalho; ciência da chefia.	Do autor e da unidade; nenhuma garantia da GOVTIC.
2 — Setorial	Uso interno limitado a um setor/unidade e grupo restrito.	Dados pessoais não sensíveis apenas com base legal e controles; sem alto impacto.	Autorização do gestor, registro, mantenedor e substituto, documentação, acesso, backup e revisão anual.	Da unidade proprietária, desenvolvedor e mantenedores.
3 — Institucional	Mais de uma unidade, integração oficial, registro autoritativo ou domínio municipal.	Pode tratar dados institucionais conforme finalidade e aprovação.	Demanda formal, parecer e homologação GOVTIC, arquitetura corporativa, testes, monitoramento e SLA.	Definida no termo de homologação e catálogo oficial.
4 — Crítico/alto impacto	Serviço externo transacional, decisão sobre direitos, dados sensíveis, saúde, finanças, segurança, agente autônomo.	Exposição ou dano potencial elevado.	AIA/RIPD conforme o caso, análises técnica/jurídica/privacidade, CGTI, testes reforçados e supervisão humana.	Institucional, formalmente definida; vedada implantação independente.

REGRA DE OURO

A classificação é determinada pelo maior risco. Uma “planilha pequena” que decide benefício ou contém dados sensíveis não é Nível 1 ou 2; uma aplicação grande de simples consulta pública pode ter controles moderados, conforme análise.

ANEXO II

CONTROLES MÍNIMOS POR NÍVEL

Controle	Nível 0	Nível 1	Nível 2	Nível 3	Nível 4
Registro no inventário	Após 60 dias ou antes de compartilhar	Quando recorrente	Obrigatório	Obrigatório	Obrigatório
Autorização da chefia/gestor	Não, dentro do sandbox	Ciência	Obrigatória	Obrigatória	Obrigatória
Mantenedor substituto	Não	Não	Obrigatório	Obrigatório	Obrigatório
Controle de versão/repositório	Recomendado	Recomendado	Obrigatório	Obrigatório institucional	Obrigatório institucional
Documentação funcional e técnica	Mínima	Mínima	Obrigatória	Completa	Completa + impactos
Controle individual de acesso	Sem dados reais	Quando aplicável	Obrigatório	Obrigatório + revisão	Obrigatório + revisão reforçada
Segredos fora do código	Obrigatório	Obrigatório	Obrigatório	Obrigatório	Obrigatório
Backup e teste de restauração	Não aplicável a dados reais	Quando houver dados	Obrigatório	Corporativo	Corporativo e testado
Logs/trilha de auditoria	Opcional	Quando aplicável	Conforme risco	Obrigatório	Obrigatório e monitorado
Revisão de código gerado por IA	Obrigatória antes de uso real	Obrigatória	Obrigatória	Obrigatória por revisor apto	Revisão reforçada e evidenciada
Análise de vulnerabilidades/dependências	Antes da promoção	Básica	Básica e periódica	Automatizada e periódica	Automatizada + testes especializados
Separação dev/teste/produção	Sandbox	Não aplicável ou recomendada	Conforme risco	Obrigatória	Obrigatória e segregada
RIPD/AIA	Não	Não	Se reclassificado	Conforme risco	Obrigatório quando aplicável
Revisão anual	Não	Na mudança	Obrigatória	Obrigatória	Contínua + anual

Os atos complementares poderão detalhar ou elevar controles de acordo com a natureza dos dados, o impacto e a evolução das ameaças, sem descaracterizar o rito simplificado dos níveis inferiores.

ANEXO III

CONTEÚDO MÍNIMO DO REGISTRO E TERMO DE CIÊNCIA

Bloco	Informações mínimas
1. Identificação	Nome da solução; unidade; finalidade; processo de trabalho; data de início; situação (experimento, produção, descontinuação).
2. Responsáveis	Proprietário do processo; desenvolvedor; mantenedor; substituto; chefia que autorizou; contatos institucionais.
3. Alcance	Usuários; setores; acesso interno ou externo; criticidade; dependência do serviço; classificação proposta.
4. Dados	Categorias de dados; presença de dados pessoais/sensíveis; base legal; fonte; retenção; compartilhamentos; registro autoritativo.
5. Tecnologia	Linguagens; banco de dados; frameworks; bibliotecas; versões; hospedagem; repositório; serviços externos.
6. Inteligência artificial	Ferramenta/modelo; finalidade; dados enviados; uso no desenvolvimento ou na execução; responsável pela revisão; restrições contratuais.
7. Segurança	Autenticação; perfis; segredos; criptografia; logs; backup; restauração; dependências; testes; vulnerabilidades conhecidas.
8. Continuidade	Rotina de suporte; atualização; documentação; substituto; exportação de dados; plano de indisponibilidade e descontinuação.
9. Declarações	Ciência de que registro não é homologação; dever de comunicar incidente; proibição de dados em IA externa; obrigação de entrega dos ativos; responsabilidade administrativa interna conforme este Decreto.
10. Aprovações	Assinaturas ou aceite eletrônico do autor, mantenedor, chefia e proprietário do processo; pareceres adicionais conforme o nível.

TERMO DE CIÊNCIA — REDAÇÃO SUGERIDA

“Declaro que as informações prestadas são verdadeiras; que compreendo que o registro não equivale a homologação ou suporte pela GOVTIC; que mantereirei a solução dentro do escopo autorizado; que não inserirei dados protegidos, credenciais ou código interno em ferramentas externas não homologadas; que revisarei resultados gerados por IA; que comunicarei imediatamente incidentes; e que entregarei à unidade todo código, dado, documentação e acesso produzido no exercício funcional.”

ANEXO IV

CATÁLOGO TECNOLÓGICO INICIAL — DIRETRIZ PARA REGULAMENTAÇÃO COMPLEMENTAR

Categoria	Padrão inicial	Situação e condicionantes
Banco relacional corporativo	PostgreSQL	Preferencial e suportado; obrigatório para Níveis 3 e 4 em novas soluções internas relacionais, salvo exceção.
Banco local/embarcado	SQLite; DuckDB e equivalentes	Permitido em Níveis 0 a 2 dentro do alcance autorizado, com exportação, proteção e backup conforme o risco.
Banco especializado	Busca, cache, séries temporais, grafos, documentos, analítico	Permitido mediante justificativa; nos Níveis 3 e 4 depende de aprovação técnica.
Linguagem principal municipal	Dart	Preferencial e recomendada para novas aplicações internas, conforme arquitetura e capacidade de manutenção municipal.
Dados, IA e automação	Python	Permitida e recomendada quando tecnicamente adequada, com controle de dependências, ambientes e segurança.
Aplicações web	JavaScript/TypeScript	Permitidas quando adequadas ao frontend, integrações ou ecossistema escolhido; observar versões e cadeia de dependências.
Legado	PHP	Tolerado e suportado conforme sistemas existentes; novos módulos relevantes devem avaliar modernização e segurança.
Outras linguagens	Java, C#, Go, Rust e outras	Possíveis mediante adequação, competência disponível e justificativa de continuidade nos Níveis 3 e 4.
Controle de versão	Git em repositório institucional	Obrigatório para Níveis 2 a 4 e recomendado para Níveis 0 e 1.
Segredos	Cofre ou variáveis protegidas	Obrigatório; proibido armazenar senha, token ou certificado diretamente no código ou repositório.
Ferramentas de IA	Catálogo específico	Somente ferramentas homologadas poderão tratar categorias de informação expressamente autorizadas.

Este Anexo tem natureza orientadora para a primeira resolução do CGTI. Recomenda-se que versões, frameworks e produtos específicos permaneçam fora do texto permanente do Decreto e sejam atualizados no Catálogo Municipal.